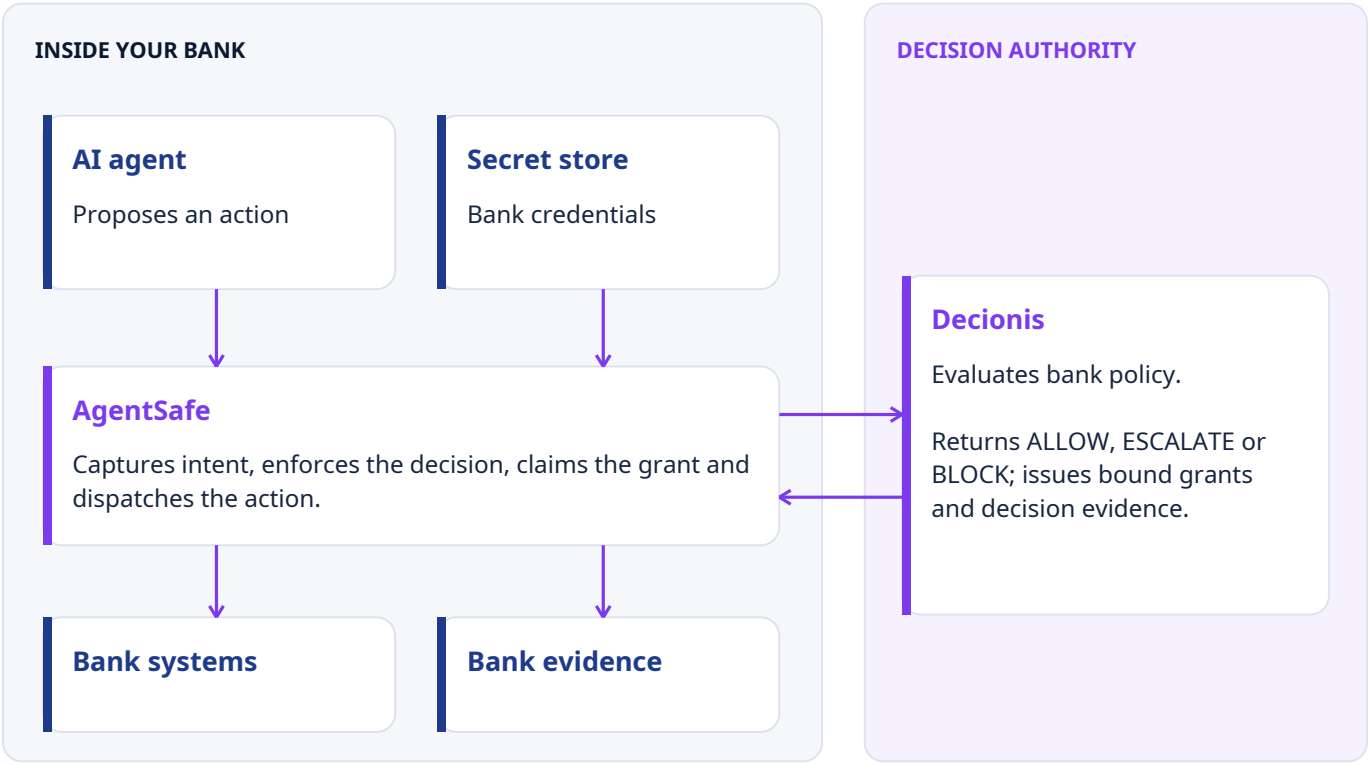
EXECUTION AUTHORITY

AgentSafe for banks

An independent authorization check between an AI agent's proposal and the action your bank executes.

The bank-operated deployment



Intent and lifecycle calls cross the boundary over authenticated HTTPS. For cards, the bank's issuer hook asks AgentSafe to match a previously held grant, or to evaluate an authorization that has no hold at the commit boundary; the issuer executes the authorization.

ALLOW

Execute only after the exact grant is verified and claimed.

ESCALATE / HOLD

Wait before the action. Approval is evidence for a new decision.

BLOCK

The governed action does not reach the bank system.

DATA AND CONTROL

A deliberate data boundary

This table describes data sent to the decision service. The managed cloud gateway also processes the full relayed request; see the deployment options on pages 4-6.

DATA	TRUSTED EXECUTOR	HTTP GATEWAY
Bank credentials	Resolved inside the bank for registered handlers.	Client headers can be relayed upstream; their raw values are not included in the policy request.
Intent and context	Declared action, target, parameters and signals go to the authority.	Method, path, query and configured identity/context go to the authority.
Request body	An adapter controls the declared parameters. Those parameters may contain business data.	Small JSON bodies are embedded by default (up to 64 KiB). Set maxEmbeddedBodyBytes to 0 to disable embedding.
Response and result	Built-in handlers return bounded result/effect evidence. Review custom adapters' output.	The upstream response is relayed to the caller; it is not sent as the policy request.
Card data	Use opaque issuer token references. The cards profile refuses PAN-shaped card references.	A generic proxy does not automatically sanitize PANs or sensitive fields in bodies and URLs.

A digest binds data; it does not remove data

Body embedding can be disabled while the raw bytes remain hash-bound. Path, query, intent parameters and signals still need the bank's data classification review.

Policy and failure remain explicit

The bank owns policy and its approver roles. Enforcement defaults to fail closed when authority is unavailable. The gateway also supports an explicit fail-open configuration, which forwards ungoverned traffic; exclude it from a strict bank enforcement profile. Shadow mode observes policy while forwarding traffic, subject to transport and admission guards.

JOINT CARD DELIVERY

Koard + Decionis

Koard is the design partner for cardholder-present verification before an agentic card transaction. Together, the flow links presence to a precise purchase and a bank-controlled authorization boundary.

OWNER	RESPONSIBILITY
Koard	Prove cardholder presence for the intended card and sign evidence bound to the purchase intent.
Decionis	Verify admitted evidence, apply bank policy and issue a short-lived, single-use execution grant.
AgentSafe	Hold the grant in the bank; match the issuer's authorization request and claim the grant once.
Issuer	Own final approve/decline, account and fraud controls, the processor integration and the outcome report.

01 Before card use

Capture purchase intent. Complete Koard verification for the cardholder-present flow. Re-evaluate; hold the grant on ALLOW.

02 At authorization

Match token, merchant, currency and amount ceiling; claim once. Answer APPROVE or NO_MATCH. With no hold, policy can answer PENDING for the cardholder's tap in the fraud queue.

03 After the result

The issuer reports approved or declined. AgentSafe compares the observed effect and submits finalization evidence.

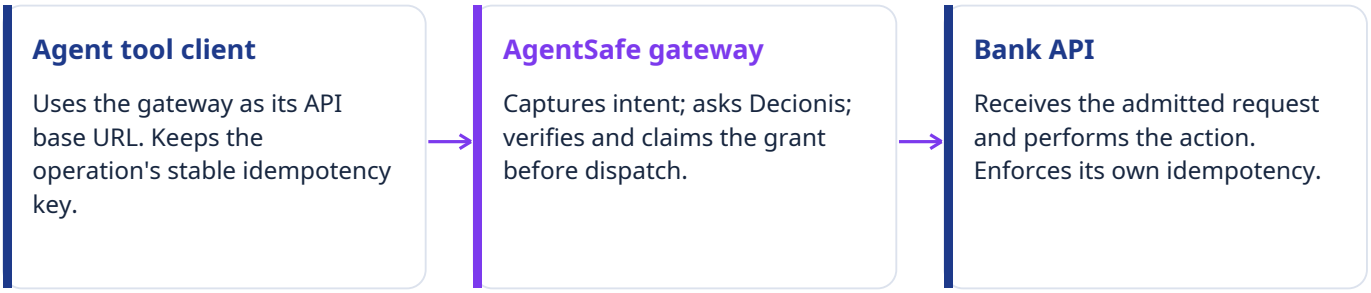
Presence, execution authority and issuer approval are separate

A Koard proof is evidence, not permission. AgentSafe's APPROVE means a matching grant was claimed. The issuer still makes the card-network decision. NO_MATCH requires an explicit bank policy response.

GATEWAY PLACEMENT

Put agent calls through AgentSafe

Route each tool's consequential HTTP calls through the gateway before they reach the system that performs the action.



Make the gateway the only permitted route

A base URL change is routing. Restrict direct API access from the agent using network or provider controls, and test that bypass fails. Protect the gateway's HTTP listener with the bank's TLS ingress or mesh.

The tool changes its address; the gateway keeps the upstream

```
Before: POST https://payments.bank.example/payments
After:  POST https://agentsafe.bank.example/payments
Upstream on gateway: https://payments.bank.example
```

Keep the method, relative path, query, body and upstream authentication. Configure one gateway per upstream; a base path is added only once. This is a reverse proxy, not a generic HTTP_PROXY / CONNECT endpoint. Changing the model endpoint alone does not govern separate tool calls.

Choose the integration surface

Addressed gateway: configure the tool or SDK base URL and govern POST, PUT, PATCH and DELETE. GET, HEAD and OPTIONS must remain safe at the API.

Transparent interception: use the supported sidecar when URLs cannot change; governing HTTPS requires the workload to trust the interception CA. Observation alone is not enforcement.

Trusted executor: use explicit action APIs for bank-owned credentials, proposer/operator separation and the Koard card flow.

ON-PREMISES SETUP

Deploy inside the bank

The gateway and the decision service can be placed independently. A bank-operated gateway can enforce using the hosted Decionis authority.

Keep the relay in the bank; choose the policy data deliberately

Agent to gateway to bank API stays on the bank's network. Intent, query, context and embedded JSON fields go to the configured authority. Turning body embedding off does not redact the other fields.

01

Choose the host or cluster

Pin the approved image digest. Run the gateway in Docker on a bank host, or use the gateway Helm chart beside the protected Service. Put TLS in front of the listener.

02

Mount the authority credential

Set the workspace organization and HTTPS authority endpoint. Production reads the key from a secret file, not a key value in environment variables. Keep it separate from agent credentials.

03

Configure the upstream and named routes

Point the tool at the gateway; keep the bank API as upstream. Start in shadow with unmatched writes governed. Restrict both ingress and bypass, and allow the required authority egress.

04

Start, observe and verify

Run agentsafe proxy --config agentsafe.yaml, or install the chart. Check health, then test actual decisions and effects. Retain per-replica evidence and plan routing for held approvals.

```
# Runtime YAML: agentsafe.yaml
authority:
  mode: shadow
  failurePolicy: failClosed
interception:
  unmatched: govern
```

Promote after validation. Runtime YAML uses authority.mode: enforcement; Helm uses gateway.mode: enforcement. Keep fail closed. A bank-run authority is the self-managed tier on page 7; the local demo is not a production authority.

MANAGED CLOUD SETUP

Connect to the hosted gateway

The assigned tenant endpoint is a separate deployment option from running the gateway inside the bank and using a hosted authority.

Current managed gateway: shadow only

The hosted runtime refuses enforcement mode. Admitted requests can create real effects at the API while Decionis observes policy. For enforcement, run a bank-operated gateway with the configured authority.

01

Obtain the assigned endpoint and keys

Decionis onboards the tenant and supplies its URL, ingress key, origin-proof token, limits and report access. Confirm region and retention. There is no self-serve setup assumed here.

02

Check the API is compatible

Use a public HTTPS origin with valid TLS. The relay cannot present an upstream client certificate, reach private APIs, stream responses or upgrade WebSockets.

03

Prove control of the origin

Serve the issued token at /.well-known/agentsafe-upstream without authentication or redirects. Keep it published and wait for the proof check before sending business traffic.

04

Change the tool base URL

Use the assigned tenant host and add AgentSafe-Tenant-Key from the application's secret store. Keep the API credential separate. The cloud gateway processes the full relayed request.

05

Send an approved test operation

Check the passthrough response and shadow observation. A would-be BLOCK still reaches the API. Use the operator's report access; a tenant key does not open status or metrics.

```
POST https://TENANT_ID.decionisedge.com/payments
AgentSafe-Tenant-Key: ISSUED_INGRESS_KEY
Authorization: Bearer UPSTREAM_API_CREDENTIAL

Expected: agentsafe-mode: SHADOW
          agentsafe-execution: PASSTHROUGH
```

Complete configuration, Docker and Helm commands, origin-proof details and acceptance checks: docs/gateway/deployment.md in the accompanying repository.

HOSTING TIERS

Where the authority runs

Three ways to run the authority that mints grants, written once so a security review reads the same answer here, in the deployment guide (docs/gateway/deployment.md) and at decionis.com/docs/card-authorization. In every tier the gateway, its hold store, its evidence chains and the ISO 8583 interceptor run inside the bank.

TIER	WHO MINTS THE GRANTS	PRESENCE AND ARRANGEMENT
Hosted	Decionis, multi-tenant, at api.decionis.com in one Azure region: Central US today, regional residency planned.	The Decionis Presence service for bank-role escalations; a cardholder's tap never goes through it. Arranged by onboarding: a workspace, its organisation id and a service key. The default.
Dedicated single-tenant	Decionis, in a deployment for one bank: its own database and Key Vault, so its own signing keys, in an agreed region.	Presence as hosted. An explicitly agreed deployment; it does not exist for a bank until agreed, and nothing here assumes it.
Self-managed, commercial licence	The bank, from the versioned Helm chart, in its own cluster with its own Postgres, egress-only or air-gapped. Decisions, dossiers and policy stay inside.	Presence connected by service token and pinned keys; no self-managed Presence is offered, and a bank whose escalations go only to the cardholder's tap needs none. The edge evaluator module comes with the licence when latency puts the claim at the edge.

What never leaves the bank, in any tier

The hold store, the evidence chains, the card hold key, the ISO 8583 tokenizer key, the bank's credentials and the card number stay inside the bank. Only the managed gateway on page 6 is Decionis-run, and it is shadow only.

Which tier a bank needs

Hosted is the default, and the shadow weeks run there. Dedicated single-tenant is for a bank that requires its own signing keys and region without running the service. Self-managed is for a bank whose decisions, dossiers and policy may not leave it, and brings the edge evaluator for a local claim.

Assurance profile as supplied in October 2026. Azure Central US; default dossier retention of 365 days, configurable, with deletion on request. SOC 2 and an independent assessment were not yet completed. Confirm the current region, retention, licensing and assurance evidence during bank diligence.

KEY CUSTODY

Where every signing key lives

Whose custody each key is in, by tier. Decionis signs grants, dossiers and policy bundles with Ed25519; the bank's own keys never reach Decionis. Variable names and rotation runbooks are in the deployment guide.

KEY	HOSTED	DEDICATED SINGLE-TENANT	SELF-MANAGED
The execution grant key, the decision dossier key and the evidence pack key (Ed25519; a previous grant key during a rotation)	Key Vault secrets of the Decionis deployment, purge-protected: one active grant key per deployment, not one per tenant	The bank's own Key Vault in its deployment: one key per bank	The bank's secret manager, supplied to the chart as the API Secret
The policy bundle signing key; the edge evaluator pins its public JWKS	A Decionis Key Vault secret, rotated with overlap under its runbook	Decionis's, as hosted: Decionis signs bundles for every tier	Decionis's; the bank pins the public JWKS and verifies offline
The Presence Record keys	The Presence service's own; the authority pins their thumbprints	As hosted	As hosted; the thumbprints are pinned in the bank's API Secret
A presence provider's keys: Koard's JWKS, or a key the bank registers itself	The provider's own; Decionis holds public keys only, in the directory and the bank's admissions	As hosted	As hosted, in the bank's authority
The bank's workspace key and, in DIRECT escalation, its Presence key	The bank's secret store, mounted as files; production refuses values in environment variables	As hosted	As hosted
The gateway's own keys: TLS, evidence signing, usage reports, the card hold key, the ISO 8583 tokenizer key, store connection strings, downstream and principal credentials	The bank's secret store, never Decionis's: read at the moment of use and printed nowhere; the card number never leaves the bank's process	As hosted	As hosted

The HSM-backed option

Key Vault's HSM-backed keys and Managed HSM do not hold Ed25519, so the grant, dossier and bundle keys are software keys kept as Key Vault secrets, purge-protected and rotated with an overlap. A dedicated or self-managed deployment that requires HSM custody of the grant key gets a change of key type, made per deployment on request and verified end to end before enforcement; it is not a switch.

DEPLOYMENT AND ACCEPTANCE

Start with one bank workflow

Make the scope, data boundary, failure policy and evidence requirements reviewable before enabling enforcement. AgentSafe is Apache-2.0 source; a dedicated or self-managed authority is a commercial arrangement, as on page 7.

01

Choose the action and integration

Use the gateway for governed HTTP calls or the trusted executor for explicit actions and bank adapters. Card matching is an executor API; the ISO 8583 interceptor puts it on the wire.

02

Configure identity, secrets and egress

Separate proposer, issuer-app and issuer-hook principals. Keep privileged credentials at the execution boundary, restrict bypass paths, allow only the authority, secret-store and bank endpoints.

03

Observe and tune policy

Run a controlled shadow workflow. Review decisions, submitted data and missing signals with risk and operations. Shadow observations do not create card execution grants.

04

Enforce and exercise failures

Verify ALLOW and claim, BLOCK, ESCALATE, PENDING, expiry, replay, restart and timeout. Measure the hook's full latency, including the claim, against its deadline and its placement's budget.

05

Roll out with operational ownership

Enable one issuing range at a time. Route SIEM evidence, monitor open attempts, rehearse the stop and key revocation, and document the issuer's NO_MATCH policy.

Replicas, restarts and latency

Holds are keyed by card and merchant. One replica keeps them in process; several replicas, or holds that must survive a restart, share a Postgres hold store (EXECUTOR_CARD_HOLDS_STORE=postgres) whose rows are sealed under a key in the bank's secret store, so the hook and its result may reach any replica. Hook answer budgets at the 99th percentile: 150 ms with the hosted authority in the same cloud region, 300 ms across regions, 10 ms with a local claim at the edge; the in-process match is under a millisecond.

Enforcement on one range, with a stop

The ISO 8583 interceptor governs only the issuing ranges named in its binRanges; everything else passes to the host untouched and is recorded as ungoverned. POST /v1/control/halt by an operator holding halt, or the halt file on the host, stops new work: the hook answers NO_MATCH with EXECUTOR_HALTED, and the interceptor's fail policy says whether a frame is then forwarded or declined.